

CISSP Printable Practice Exam 13 - Domain 5 - Identity and Access Management (IAM)

Practice Exam 02 - Domain 5

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP2-079)

Scenario: A biotechnology laboratory uses proximity badges at the entrance to a room containing controlled research materials. Security personnel have observed employees holding the door for coworkers, and management is concerned that a borrowed badge could be used without detection.

Which control would BEST address both concerns at the restricted-room entrance?

- A. Increase the frequency of inventory reconciliation for materials stored in the room
- B. Install a camera and review recorded footage after a discrepancy is reported
- C. Replace proximity badges with badges that display larger employee photographs
- D. Require a badge and biometric verification through a mantrap that admits one person at a time

Question 2 (CISSP2-080)

Scenario: A publishing company requires strong multifactor authentication for normal sign-in, but its help desk resets credentials after callers provide an employee number and date of birth. An attacker recently used publicly available information to take over an executive's account.

What is the MOST effective improvement to the recovery process?

- A. Require callers to answer additional questions based on biographical information
- B. Use a pre-established, high-assurance recovery method with identity proofing comparable to enrollment
- C. Ask the help desk to notify the user's manager several hours after each reset
- D. Make normal sign-in passwords longer while leaving the reset process unchanged

Question 3 (CISSP2-081)

Scenario: A travel application assigns a session identifier before login and continues using the same identifier after the user authenticates. A security tester can cause a victim to begin with a session identifier already known to the tester.

Which application change BEST mitigates this weakness?

- A. Increase the maximum lifetime of unauthenticated sessions
- B. Display the session identifier to the user after each successful login
- C. Regenerate the session identifier upon authentication and invalidate the prior identifier
- D. Store the user's authorization roles inside the existing identifier

Question 4 (CISSP2-082)

Scenario: A consulting firm is revising credential practices after finding reused employee passwords and administrator passwords embedded in deployment scripts.

Which TWO actions would BEST address the identified credential-management risks? Select 2 of the 5 options below.

- A. Provide an approved password manager for unique employee credentials
- B. Store automation secrets in a controlled secrets-management service with rotation
- C. Require all project members to share one complex password
- D. Permit scripts to contain passwords if the source-code repository is private

- E. Set every employee password to expire at the same predictable time

Question 5 (CISSP2-083)

Scenario: An engineer presents valid credentials and successfully completes multifactor authentication. The engineer then requests a payroll report that is not permitted by the assigned job function.

Which statement BEST explains why the request should be denied?

- A. Identification failed because the payroll report belongs to another department
- B. Authentication failed because multifactor authentication applies only to administrators
- C. Authorization failed because verified identity does not confer permission to every resource
- D. Accountability failed because authenticated activity cannot be attributed to a user

Question 6 (CISSP2-084)

Scenario: A legal services organization uses SAML single sign-on with multiple external service providers. The identity provider's assertion-signing certificate will expire soon, and an uncoordinated replacement could cause every provider to reject otherwise valid assertions.

What is the BEST approach to the certificate rollover?

- A. Wait for expiration, replace the certificate, and ask providers to disable signature validation temporarily
- B. Keep the expired certificate indefinitely because existing federation agreements remain valid
- C. Send the identity provider's private signing key to each provider before the change
- D. Publish and exchange updated trusted metadata in advance, allow a controlled overlap, and test each trust relationship

Question 7 (CISSP2-085)

Scenario: A municipal agency is building a native mobile application that needs delegated access to a resident's service records. The application cannot safely keep a static client secret, and the architect is concerned that an intercepted authorization code could be redeemed by another application.

Which approach BEST addresses the concern?

- A. Embed one long-lived confidential client secret in every installed copy of the application
- B. Send the resident's password directly to the resource server with each API request
- C. Use the authorization code flow with a proof key that binds code redemption to the initiating client instance
- D. Place a bearer access token in a publicly accessible redirect address

Question 8 (CISSP2-086)

Scenario: An education platform receives an OpenID Connect ID token after a user signs in through an external identity provider. The platform currently decodes the token and trusts the displayed subject without further checks.

Which validation is MOST important before creating the local session?

- A. Accept the token whenever its subject value matches an existing local username
- B. Treat the accompanying access token as a substitute for all ID-token validation
- C. Remove the expiration claim so users do not need to authenticate again

D. Confirm the signature and verify the issuer, audience, and token validity conditions

Question 9 (CISSP2-087)

Scenario: A construction consortium will automatically create local accounts when subcontractor users first authenticate through a trusted identity provider. The application can map incoming claims to local roles.

Which TWO controls would BEST limit inappropriate access from claim errors or excessive partner entitlements? Select 2 of the 5 options below.

- A. Allow only approved claim values through an explicit mapping to least-privilege local roles
- B. Set automatically created accounts to a restricted default unless stronger access is specifically authorized
- C. Map every unknown partner group to the application's highest operational role
- D. Accept authorization claims from any issuer that can reach the application
- E. Preserve every federated account permanently after its first successful sign-in

Question 10 (CISSP2-088)

Scenario: A healthcare network wants seamless single sign-on across employee scheduling, internal news, and a system that authorizes high-impact medication changes. The current identity session is established with a basic authenticator suitable for low-risk applications.

What is the BEST way to handle access to the medication system?

- A. Accept the existing session because all applications share the same identity provider
- B. Require step-up authentication that meets the medication system's assurance requirement
- C. Create one shared medication account for clinicians who already have an SSO session
- D. Remove authentication from the medication system and rely only on network location

Question 11 (CISSP2-089)

Scenario: A wholesale distributor permits purchasing staff to create suppliers and accounts-payable staff to release supplier payments. Management wants to prevent one person from holding both capabilities while continuing to administer access through job functions.

Which control BEST meets the requirement?

- A. Allow each supplier record owner to grant payment-release access
- B. Assign both permissions to one role and review transaction logs annually
- C. Define separate RBAC roles and enforce a mutually exclusive role constraint
- D. Base access solely on whether the request originates during business hours

Question 12 (CISSP2-090)

Scenario: In a small design studio, the creator of each project folder may grant or revoke access for other users. The organization does not impose classification labels, and folder owners control the access lists.

Which access control model is being used?

- A. Discretionary access control
- B. Mandatory access control
- C. Risk-based access control
- D. Rule-based access control

Question 13 (CISSP2-091)

Scenario: A chemical processing company uses a central policy decision point for access to hazardous-process controls. During a network interruption, the local policy enforcement point cannot obtain a fresh decision. Management prioritizes preventing unauthorized changes over convenience.

How should the enforcement point behave for a new high-risk request?

- A. Permit the request because the user authenticated earlier in the day
- B. Ask the requester to state verbally that the change is authorized
- C. Grant temporary owner rights until the decision point becomes available
- D. Deny the request unless an explicitly approved, securely cached policy covers it

Question 14 (CISSP2-092)

Scenario: A loan officer is permitted to initiate and approve loans as part of the job role, but policy states that the same person must not approve a loan that person initiated. Different officers may perform the two actions for each transaction.

Which authorization control BEST expresses this requirement?

- A. Apply a dynamic separation-of-duties rule using the transaction initiator
- B. Remove the approval role permanently from every loan officer
- C. Let the initiator change the loan object's access list before approval
- D. Require a higher classification label for all loan records

Question 15 (CISSP2-093)

Scenario: An energy company combines several authorization policies. A user's maintenance role permits editing a system, but an emergency rule denies all nonresponse-team changes while a safety incident is active. Both policies apply to the same request.

Which policy-combining approach BEST preserves the emergency restriction?

- A. Permit overrides, because one applicable policy grants access
- B. First applicable, using whichever policy happens to load first
- C. Deny overrides, so the applicable emergency denial controls the result
- D. Owner discretion, allowing the user to select the preferred result

Question 16 (CISSP2-094)

Scenario: A rapidly growing food distributor receives account requests through informal emails from team members. Duplicate identities and unauthorized job roles have appeared because the identity team cannot reliably confirm employment status or approving authority.

Which change should be implemented FIRST?

- A. Use an authoritative workforce record to initiate provisioning and route role approval to the accountable owner
- B. Create requested accounts immediately and reconcile employment status at year-end
- C. Let new employees select access by copying any coworker's profile
- D. Assign one generic departmental identity until each employee requests a personal account

Question 17 (CISSP2-095)

Scenario: A property management company provisions contractor accounts for short renovation projects. Project end dates often change, and accounts have remained active because no employee is clearly responsible for extensions or closure.

What is the BEST lifecycle design for these accounts?

- A. Create accounts without expiration and depend on contractors to request deletion
- B. Require an internal sponsor and approved end date, with automatic expiration unless the sponsor renews access
- C. Place all contractors in one permanent role so projects do not affect access
- D. Disable logging for expired projects to reduce retained identity data

Question 18 (CISSP2-096)

Scenario: A telecommunications provider needs on-call engineers to obtain emergency privileges when an outage prevents the normal approval workflow. The organization must restore service quickly without turning emergency elevation into untracked standing access.

Which design BEST meets both objectives?

- A. Give every on-call engineer permanent administrator access before the rotation begins
- B. Store a shared administrator password in an unmonitored team document
- C. Prohibit all elevated access until the normal approval system is restored
- D. Use individually attributable emergency elevation that expires automatically, records activity, and triggers prompt review

Question 19 (CISSP2-097)

Scenario: A software company grants temporary repository access to employees assigned to confidential client engagements. The security manager wants access removed promptly when an engagement relationship ends rather than waiting for a quarterly campaign.

Which TWO events should directly trigger reevaluation or removal of this access? Select 2 of the 5 options below.

- A. The employee is removed from the engagement roster
- B. The client's engagement is formally closed
- C. The employee receives a new manager but remains assigned to the engagement
- D. The engagement reaches an interim billing milestone without closing
- E. The repository owner changes while the engagement roster remains unchanged

Question 20 (CISSP2-098)

Scenario: During an account access review, a regional bank discovers that an employee has two individually approved entitlements that together permit creation and release of the same funds transfer. The employee still needs each function for different assigned duties.

What is the BEST response?

- A. Retain both entitlements because each was approved separately
- B. Redesign the assignment or add an enforced transaction control that prevents self-approval
- C. Ask the employee to promise not to use both permissions on one transaction
- D. Remove audit records for the two functions to reduce reviewer confusion

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP2-079) - Correct: D

A mantrap limits passage to one person, while biometric verification binds use of the badge to the enrolled individual. Inventory checks and recorded video are primarily detective and do not prevent tailgating or borrowed-badge use. A larger photograph may help an attentive guard but does not provide the same automated, layered assurance.

Question 2 (CISSP2-080) - Correct: B

Account recovery must not become a weaker path around strong authentication. A pre-established recovery factor or rigorously proofed recovery process provides assurance comparable to enrollment. More biographical questions may still rely on discoverable information, delayed notification is detective, and longer normal passwords do not correct the vulnerable reset channel.

Question 3 (CISSP2-081) - Correct: C

Rotating the identifier at the authentication boundary prevents a preselected anonymous session from becoming the victim's authenticated session. A longer lifetime increases exposure, displaying the value does not stop fixation, and adding authorization data to the known identifier can worsen the impact without changing the compromised session binding.

Question 4 (CISSP2-082) - Correct: A, B

An approved password manager supports unique credentials without forcing users to memorize each one, while a secrets-management service removes administrative secrets from scripts and supports controlled access and rotation. A shared password eliminates individual accountability. A private repository is not an appropriate secret store, and synchronized predictable expiration does not directly solve reuse or embedded credentials.

Question 5 (CISSP2-083) - Correct: C

Authentication establishes confidence in the claimed identity; authorization separately determines what that identity may access. The engineer was identified and authenticated successfully, but lacks the required payroll entitlement. Because the session is associated with the engineer's identity, accountability has not inherently failed.

Question 6 (CISSP2-084) - Correct: D

Advance metadata exchange, controlled key overlap, and testing let relying parties trust the new signing certificate without an abrupt outage. Disabling validation permits forged assertions, and continuing with an expired certificate can cause rejection and weakens key lifecycle management. Service providers need the public trust material, never the identity provider's private signing key.

Question 7 (CISSP2-085) - Correct: C

A proof key for code exchange binds the authorization request and token exchange, reducing the value of an intercepted code for a public client that cannot protect a static secret. Embedding one secret makes it recoverable from application copies. Direct password handling defeats delegated authorization, and exposing a bearer token in a public redirect location increases token theft risk.

Question 8 (CISSP2-086) - Correct: D

The relying party must validate the token's cryptographic signature and ensure claims such as issuer, audience, and validity period match the expected transaction. A matching username does not establish token authenticity. An access token serves resource authorization and does not replace ID-token validation, while ignoring expiration permits replay beyond the

intended lifetime.

Question 9 (CISSP2-087) - Correct: A, B

An explicit allowlisted mapping prevents unexpected partner claims from silently creating powerful local entitlements, and a restricted default limits exposure during just-in-time account creation. Elevating unknown groups and trusting arbitrary issuers fail securely neither at the trust boundary nor at authorization. Permanent retention also ignores changes in partner status and lifecycle obligations.

Question 10 (CISSP2-088) - Correct: B

SSO improves usability but does not make every initial authentication appropriate for every risk level. Step-up authentication lets the sensitive application require stronger assurance at the point of access. A common identity provider alone does not resolve assurance mismatch, while shared accounts and network-only trust weaken authentication and accountability.

Question 11 (CISSP2-089) - Correct: C

RBAC can group permissions by business function and enforce static separation of duties by preventing conflicting role assignments. Owner-granted access is discretionary and may bypass the conflict rule. Combining the permissions relies on after-the-fact detection, while a time rule does not separate supplier creation from payment approval.

Question 12 (CISSP2-090) - Correct: A

Discretionary access control allows a resource owner to determine who may access the resource, commonly through an access control list. MAC relies on centrally enforced labels, risk-based control evaluates contextual risk, and rule-based control applies centrally defined conditions rather than owner discretion.

Question 13 (CISSP2-091) - Correct: D

Fail-secure behavior denies a new sensitive request when authorization cannot be established, except where a deliberately designed and current local policy supports it. Prior authentication does not prove current authorization. Verbal assertion is not policy evaluation, and automatic owner rights would expand privilege during a control failure.

Question 14 (CISSP2-092) - Correct: A

Dynamic separation of duties evaluates prior actions in the specific transaction and prevents the initiator from serving as approver. Permanently removing approval would be a broader static restriction than required. Owner-controlled lists do not reliably enforce the conflict, and classification labels do not represent transaction participation.

Question 15 (CISSP2-093) - Correct: C

A deny-overrides strategy ensures that the applicable emergency prohibition is not weakened by a routine role permission. Permit overrides would defeat the safety restriction. Depending on incidental evaluation order is fragile unless policy order is an intentional design, and the requester must not choose the authorization outcome.

Question 16 (CISSP2-094) - Correct: A

An authoritative source establishes that the person has a valid organizational relationship, while accountable approval confirms the business need for assigned access. Delayed reconciliation leaves unauthorized accounts active. Copying a coworker can propagate exceptions or excessive access, and generic identities prevent individual accountability.

Question 17 (CISSP2-095) - Correct: B

An accountable internal sponsor and time-bounded access connect each contractor identity to a continuing business need. Automatic expiration provides a safe default, while controlled renewal handles legitimate schedule changes. Contractor self-reporting is unreliable, a permanent common role ignores project scope, and logging is unrelated to timely account termination.

Question 18 (CISSP2-096) - Correct: D

Controlled break-glass elevation supports urgent recovery while retaining individual attribution, limiting duration, recording use, and enabling review of the exception. Permanent administrator rights create unnecessary standing privilege. A shared password weakens custody and accountability, while prohibiting all elevation could prevent essential restoration work.

Question 19 (CISSP2-097) - Correct: A, B

Removal from the engagement and formal closure of the engagement both end the business basis for repository access, so either should trigger prompt lifecycle action. A manager change, an interim billing milestone, or a repository-owner change may require administrative updates, but none ends the employee's active engagement assignment by itself.

Question 20 (CISSP2-098) - Correct: B

The combined permissions create a toxic entitlement condition even though each permission has a valid business purpose. The organization should restructure duties or enforce a transaction-level separation that preserves needed work without allowing self-approval. Separate historical approvals and a personal promise do not enforce the control, while removing audit evidence further weakens accountability.